

COIT20246 Cyber Security and Networking

Project Specification 1

**Small Business Network Security, OpenWrt Firewall Configuration and Cyber
Security Risk Assessment**

Student 1: Pavan Reddy Chinthalapally

Student ID: 12327397

Student 2: Patel Ronak Ghanshyambhai

Student ID: 12328755

**Business Scenario: Small IT and Business Consultancy, Brisbane, Queensland,
Australia**

4.3 Risk Assessment and Security Controls

4.3.1 Conduct a Cyber Security Risk Assessment

ID	Candidate threat / vulnerability	Scenario-specific risk	Primary asset	Asset type	Data asset	Existing control/evidence	Likelihood (1-5)	Impact (1-5)	Inherent score	Treatment / control
R01	Unauthorised access / credential compromise	Weak or compromised administrator credentials could allow privileged access to	A05 Employee credentials	Information / credential	Y	Root password changed; SSH key authentication	4	5	20	Use unique strong credentials, Ed25519 keys and restrict management access.
R02	Network interception / eavesdropping	Unencrypted HTTP exposes webpage content and network metadata to an interceptor.	A06 Business service/content information	Information / data	Y	HTTP capture demonstrated plaintext content; SSH is encrypted.	4	4	16	Use HTTPS/TLS for the production website and avoid sensitive data over HTTP.
R03	Malware / endpoint compromise	A compromised Windows workstation could expose business records or provide a route into the internal network.	A02 Windows staff workstations	Hardware / endpoint	N	Firewall and OpenWrt gateway; no endpoint security evidence recorded	3	5	15	Endpoint protection, patching, least privilege and controlled application installation.
R04	Denial of service / service disruption	Flooding or excessive requests against the public web service could reduce website availability.	A03 Business web server/uhttpd	Software / service	N	Firewall configured for traffic control	3	4	12	Rate limiting, monitoring, backup web hosting and restrictive firewall policy.
R05	Unauthorised modification	An attacker gaining administrative access could alter firewall or web-server configuration.	A09 OpenWrt firewall configuration	Software / configuration	N	SSH moved to 2222; key authentication; root password changed	3	5	15	Restrict administration, back up configuration, monitor changes and use least privilege.
R06	Information disclosure	Business/client documents or contact information could be exposed from compromised endpoints or storage.	A07 Business documents and client records	Information / data	Y	Network firewall; SSH encryption; hardening	3	5	15	Access control, encryption at rest/in transit, backups and staff awareness.
R07	Social engineering / phishing	Staff could disclose credentials or open malicious content, leading to account or endpoint compromise.	A10 Staff and IT support personnel	People	N	No phishing-specific control demonstrated	3	4	12	Security awareness training, phishing simulations and MFA where supported.
R08	Physical theft / loss	Theft of a workstation or administrator device could expose business data or SSH private keys.	A08 SSH private keys	Information / credential	Y	Private key generated with passphrase	2	5	10	Device encryption, secure storage, key backup/revocation and physical access controls.
R09	Unnecessary service exposure	An unused network service could create an additional attack surface.	A01 OpenWrt router/firewall	Hardware / network infrastructure	N	Unnecessary service disabled as part of hardening	3	4	12	Disable unused services and periodically review listening ports.
R10	ICMP/network reconnaissance	Exposed ping/ICMP can assist network discovery, although it can also support diagnostics.	A01 OpenWrt router/firewall	Hardware / network infrastructure	N	ICMP block/allow rule demonstrated	3	2	6	Permit ICMP only where operationally required and monitor unusual traffic.
R11	SSH service exposure	Leaving administration exposed on a standard port can attract automated scanning and brute-force attempts.	A01 OpenWrt router/firewall	Hardware / network infrastructure	N	SSH moved from 22 to 2222; port 22 blocked; key authentication	3	4	12	Restrict SSH source addresses, use keys, monitor logs and keep software patched.
R12	Web management interface exposure	Management web access could expose administrative functions if reachable from untrusted networks.	A01 OpenWrt router/firewall	Hardware / network infrastructure	N	Assignment requires management-interface restriction	3	5	15	Permit management only from trusted management network and verify port 81 access restrictions.

Figure 1: Cybersecurity Risk Assessment Matrix and Recommended Controls

A mini business network developed in Sections 4.1 and 4.2 is subject to a mini cyber security risk assessment, carried out with the TVAMatrix template. The assessment included 12 types of information security threats such as: unauthorised access, network interception, malware, denial of service, unauthorised modification, information disclosure, phishing, physical theft, unnecessary service exposure, ICMP reconnaissance, SSH exposure, management-interface exposure. The assets covered hardware, software/services, information/data, credentials and the people. These were business/client records, business/Service information, employee credentials and SSH private keys. The controls that already existed were firewall rules, SSH key authentication, hardening of the root password, encryption and turning off unnecessary services.

4.3.2 Recommend Security Controls

Employee credentials (A05) is the highest-risk data asset, with an inherent risk score of 20. There are three suggested security controls:

1. Multi-Factor Authentication (MFA): This decreases the likelihood of a credential being compromised. Must be activated for administrators and employees. This could result in longer logon, and use of an additional authentication mechanism will be necessary for users.

2. Strong Authentication and SSH Key Management: Use of SSH Key Management is highly encouraged and SSH keys are going to replace password access, where the private key is protected with a passphrase (Makris, 2024). Moving SSH from its own port 22 and hardening its access with port 2222 means less exposure from a brute-force approach. The key management may cause recovery and admin overhead.

3. Access Control/Firewall Restrictions: Administrative services should be networked within a management network and unneeded ports should be closed. A foundation of exit and entry firewall rules for SSH, HTTP and ICMP and management.

References

Makris, N., 2024. Cyber range development: Configuration of the cyber range environment network and monitoring tools (Master's thesis, Πανεπιστήμιο Πειραιώς).